
用户信息管理平台

安全漏洞挖掘与修复报告

`http://10.133.25.156:5000`

项目版本：V8.0 - XSS与CSRF漏洞专题

报告日期：2026年7月14日

今日课程：Day6:XSS跨站脚本与CSRF跨站请求伪造

技术栈：Python Flask / XSS / CSRF / 越权

一、课程背景

XSS(跨站脚本攻击)和CSRF(跨站请求伪造)是两类经典的Web安全漏洞。XSS利用网站未对用户输入进行过滤的缺陷，向页面中注入恶意脚本代码；CSRF则利用网站未验证请求来源的缺陷，诱使用户在不知情的情况下执行非自愿的操作。

1.1 XSS(跨站脚本攻击)

XSS攻击者将恶意脚本注入到网页中，当其他用户访问该页面时，脚本会在他们的浏览器中执行。XSS分为三种类型：存储型(数据持久化在服务器上)、反射型(恶意脚本在URL中)和DOM型(基于前端DOM操作)。

1.2 CSRF(跨站请求伪造)

CSRF攻击者构造一个恶意页面，当已登录用户访问该页面时，会在用户不知情的情况下向目标网站发送请求，执行非用户意愿的操作。CSRF的核心成因是网站没有验证请求的合法性来源。

1.3 本次实验环境

项目	说明
目标应用	基于Flask的用户管理系统
新增功能	/change-password 修改密码(无CSRF、无原密码校验)
漏洞类型	CSRF + 越权(可修改任意用户密码)
测试账号	admin/admin123

二、漏洞分析

2.1 漏洞代码

```
@app.route("/change-password", methods=["POST"])
@login_required
def change_password():
    username = request.form.get("username", "")
    new_password = request.form.get("new_password", "")
    # 漏洞1: 无CSRF Token校验
    # 漏洞2: 无原密码验证
    # 漏洞3: 可修改任意用户的密码(越权)
    sql = f"UPDATE users SET password = '{new_password}' WHERE username = '{username}'"
    c.execute(sql)
```

2.2 漏洞列表

漏洞类型	风险	说明
CSRF	高危	未验证Token，攻击者可伪造密码修改请求
越权	高危	已登录用户可修改任意人的密码
无原密码	高危	不需要知道原密码即可修改
SQL注入	高危	f-string拼接SQL语句

2.3 POC验证

```
// POC 1: admin登录后修改alice的密码
// 不需要知道alice的原密码
POST /change-password
username=alice&new_password=hacked123
// 结果: alice的密码被改为 hacked123

// POC 2: CSRF攻击(构造恶意页面)
<form action="http://目标/change-password" method="POST">
  <input name="username" value="admin">
  <input name="new_password" value="csrf_hacked">
</form>
<script>document.forms[0].submit()</script>
// 受害用户只要访问这个页面, 密码就被改了
```

三、修复方案

3.1 添加CSRF Token验证

```
// 在表单中添加CSRF Token
<input type="hidden" name="_csrf_token" value="{ { csrf_token } }">

// 在服务端验证
if request.form.get("_csrf_token") != session.get("_csrf_token"):
    return "CSRF攻击拦截"
```

3.2 验证原密码

```
old_password = request.form.get("old_password", "")
if not check_password_hash(user["password"], old_password):
    return "原密码错误"
```

3.3 从Session获取用户身份

```
# 不从表单取username
username = session.get("username")
# 只能修改自己的密码
```

3.4 修复前后对比

对比项	修复前	修复后
CSRF Token	无	有Token校验
原密码	不需要	必须验证原密码
用户身份	从表单获取	从Session获取
SQL语句	f-string拼接	参数化查询

四、修复后验证

测试	修复前	修复后
admin修改alice密码	成功(越权)	[OK] 只能修改自己的
无CSRF Token提交	成功	[OK] 被拦截
不输原密码直接改	成功	[OK] 必须输入原密码

五、总结

CSRF和XSS是Web安全中最常见的客户端攻击方式。CSRF的核心问题是"这个请求是用户自愿发出的吗"，XSS的核心问题是"这段内容是用用户输入的吗"。

安全开发原则：

1. 所有涉及数据修改的请求必须验证CSRF Token
2. 密码修改必须验证原密码
3. 用户身份从Session获取，不从客户端传入的参数获取
4. 所有SQL操作使用参数化查询

— 报告完 —

报告日期: 2026-07-14 | 课程: XSS与CSRF漏洞修复